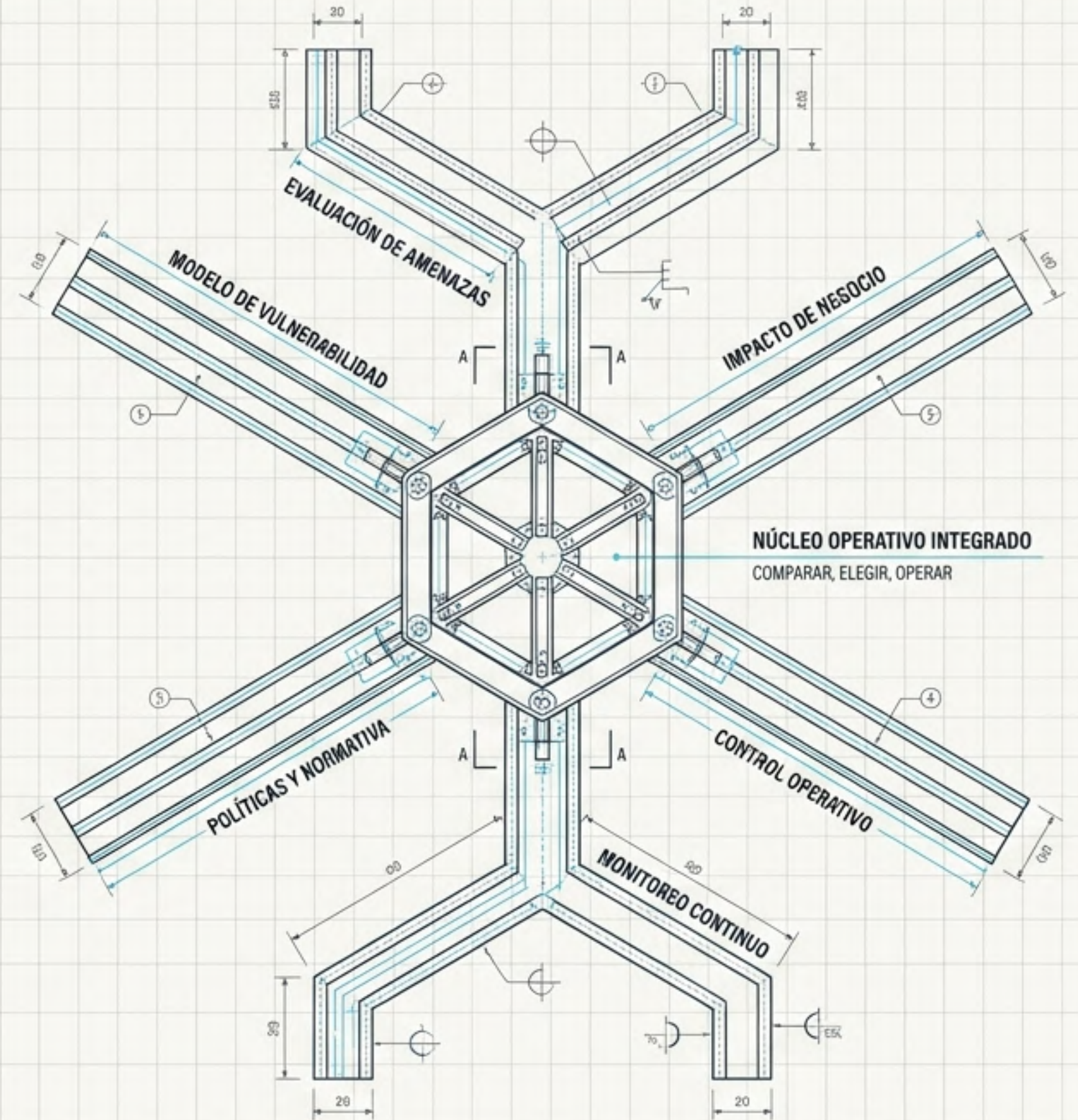


# Lección 08

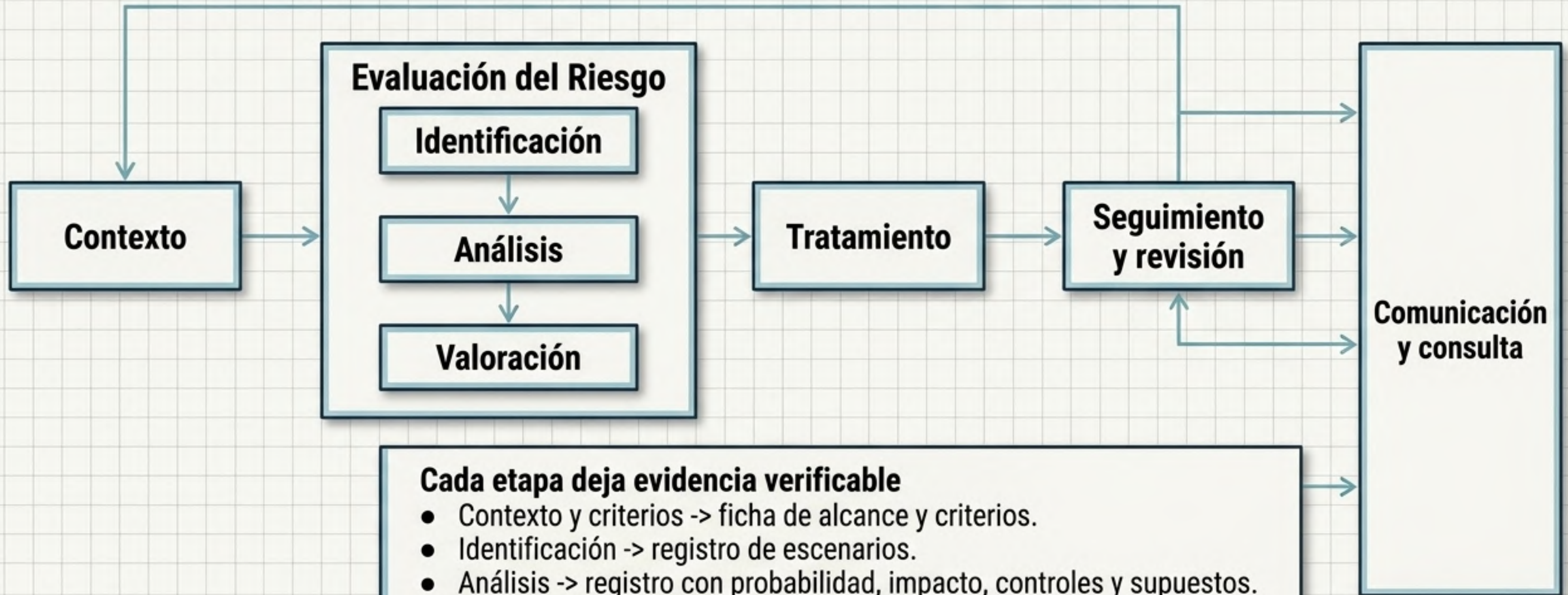
## Arquitectura del Riesgo: Comparar, Elegir y Operar

De las reglas de negocio al ciclo continuo de seguridad.

En la Lección 07 fijamos las reglas (alcance, escalas, tolerancias). Hoy elegiremos las herramientas modulares para construir y operar el ciclo sin duplicar esfuerzos.



# Gestión del Riesgo



## Cada etapa deja evidencia verificable

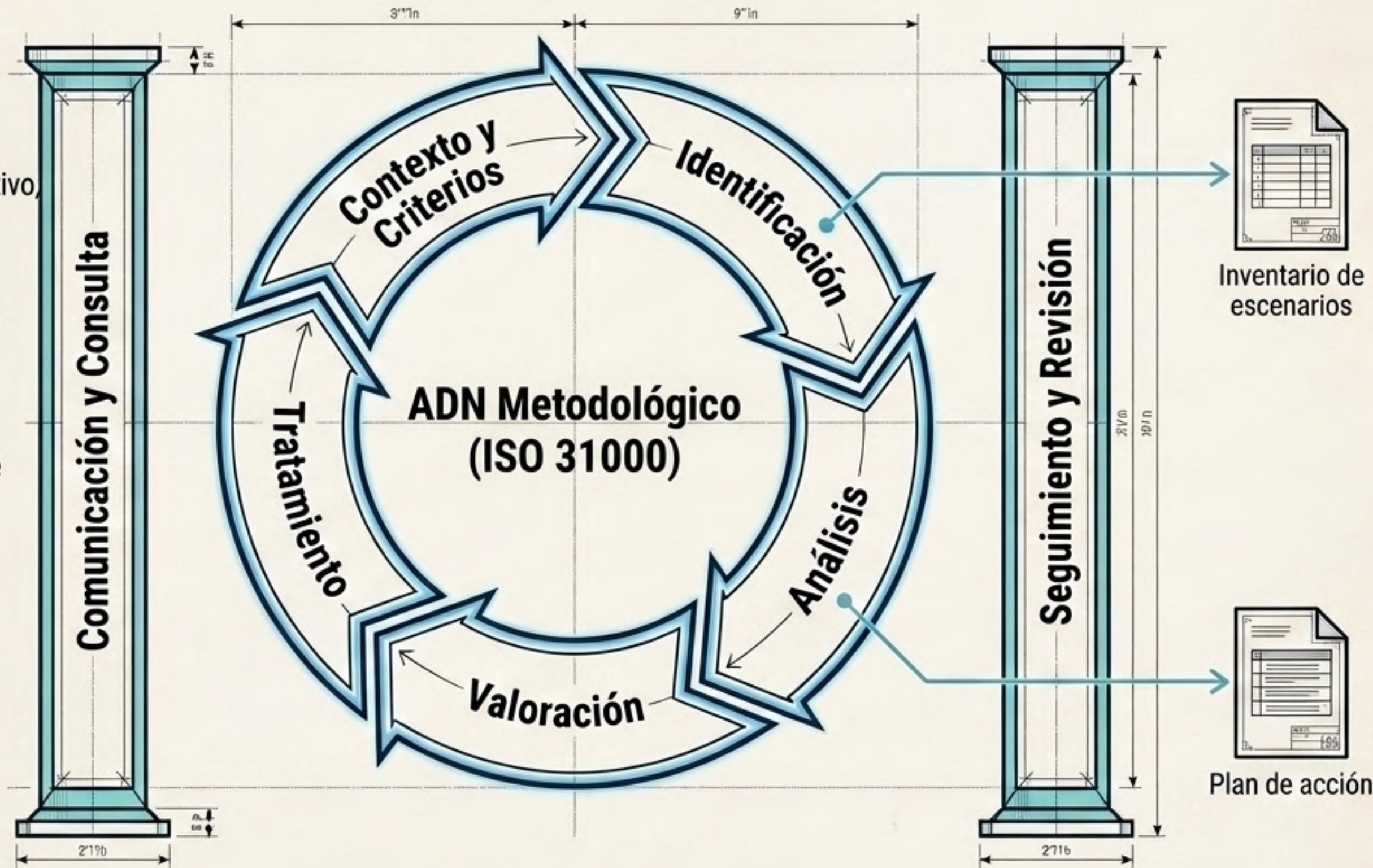
- Contexto y criterios -> ficha de alcance y criterios.
- Identificación -> registro de escenarios.
- Análisis -> registro con probabilidad, impacto, controles y supuestos.
- Valoración -> matriz o priorización.
- Tratamiento -> plan de tratamiento y aceptación.
- Comunicación -> informe o perfil.
- Seguimiento y revisión -> indicadores y acta de revisión.

# ISO 31000 - El Esqueleto Universal

**Qué es:**  
Referencia internacional de gestión del riesgo aplicable a distintos tipos de riesgo organizacional: financiero, operativo, legal, tecnológico, entre otros.

**El punto clave:**  
Proporciona principios, un marco y un proceso general para gestionar riesgos.

ISO/IEC 27005 se alinea con este proceso para aplicarlo a la seguridad de la información. Otras referencias, como las de NIST, pueden compartir etapas y objetivos similares, aunque utilizan su propia estructura.



# NIST SP 800-30 Rev.1 - La Lupa de Evaluación

## Fortalezas

- Evaluación detallada y estructurada.
- Distingue fuentes y eventos de amenaza, vulnerabilidades y condiciones predisponentes.
- Incluye ejemplos de escalas y criterios para apoyar el análisis.



Evaluación

## Contexto NIST:

SP 800-39 organiza la gestión del riesgo mediante:  
Frame → Assess → Respond → Monitor.

SP 800-30 desarrolla en detalle principalmente la etapa Assess.

## Límite Crítico

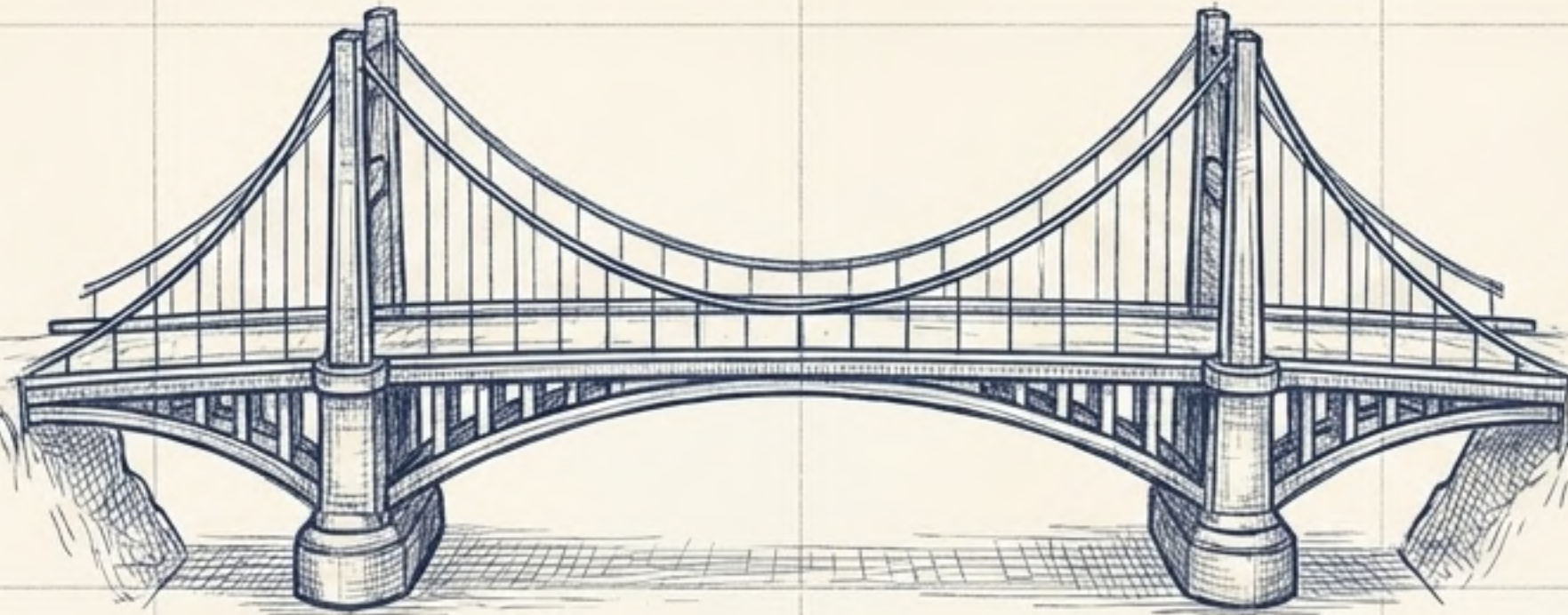
- Se concentra en la evaluación del riesgo.
- No desarrolla por sí sola todo el tratamiento, la aceptación ni el gobierno continuo del riesgo.
- Debe utilizarse dentro de un proceso de gestión más amplio.

# NIST CSF 2.0 - El Puente de Comunicación

**Operación TI**  
(Lenguaje Técnico)



**Directorio**  
(Lenguaje de Negocio)



## Tiers:

Describen el grado de formalización, integración y adaptación de las prácticas de gestión del riesgo.

No son una puntuación de riesgo ni sustituyen una evaluación por escenarios.

## Mecánica de Traducción:

Mantén Current Profile y Target Profile como mecanismo para representar el estado actual y el estado objetivo.



CSF 2.0 comunica resultados y brechas, pero no calcula probabilidad, impacto ni riesgo por escenario.

PROJECT: Risk Management Architecture

DATE: OCT 26, 2024

SCALE:

SHEET NO:

DRAWN BY: AI Architect

NTS

05

# NIST IR 8286 Family - Estructura y Conexión del Riesgo

## NIST IR 8286 Rev.1:

Conecta el riesgo de ciberseguridad con la gestión de riesgo empresarial (ERM).

## NIST IR 8286A Rev.1:

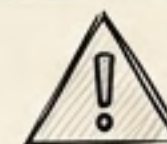
Profundiza en la identificación y estimación del riesgo y estructura la información necesaria para mantener un registro de riesgos.

Registro de Riesgos

| Escenario | Categoría | Probabilidad | Impacto | Tipo Respuesta | Propietario |
|-----------|-----------|--------------|---------|----------------|-------------|
| _____     | _____     | _____        | _____   | _____          | _____       |
| _____     | _____     | _____        | _____   | _____          | _____       |
| _____     | _____     | _____        | _____   | _____          | _____       |
| _____     | _____     | _____        | _____   | _____          | _____       |
| _____     | _____     | _____        | _____   | _____          | _____       |

### Nota:

El cálculo detallado y la priorización se operan en la siguiente etapa del ciclo.



PROJECT: Risk Management Architecture

DATE: OCT 26, 2024

SHEET NO:

DRAWN BY: AI Architect

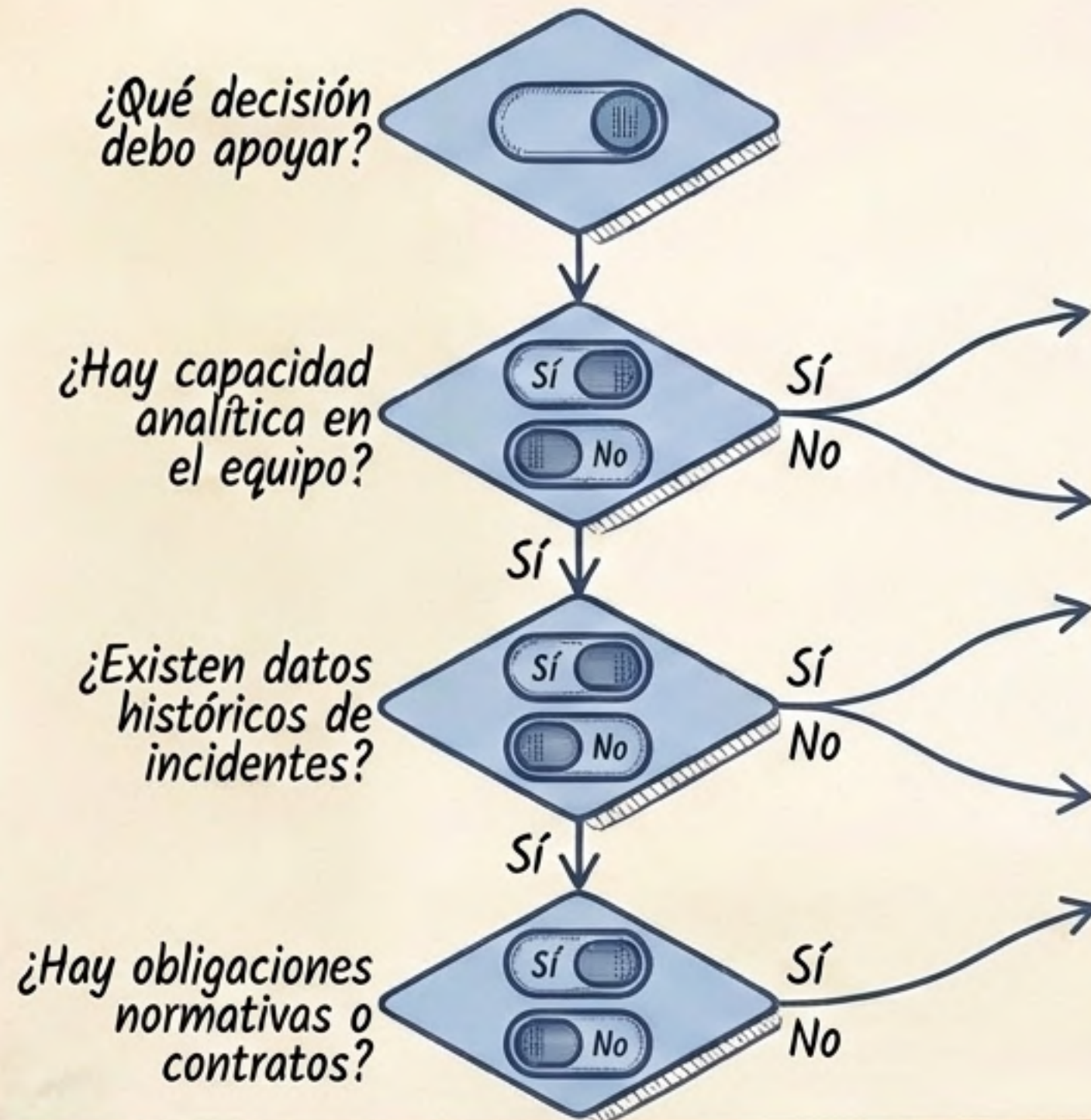
SCALE: NTS

06

# La Mesa de Selección: Tabla Comparativa

|                      | ISO/IEC 27005                                                                            | NIST SP 800-30                          | NIST CSF 2.0                                                                |
|----------------------|------------------------------------------------------------------------------------------|-----------------------------------------|-----------------------------------------------------------------------------|
| Propósito Principal  | Ciclo continuo de gestión SGSI                                                           | Diagnóstico profundo y analítico        | Comunicación de estado y brechas                                            |
| Entradas Requeridas  | Contexto, procesos y activos                                                             | Datos detallados de amenazas            | Contexto, prioridades y resultados actuales/objetivo.                       |
| Resultado Principal  | Proceso y registro continuo de gestión del riesgo, incluyendo tratamiento y seguimiento. | Diagnóstico valorado por escenario      | Distancia entre perfil actual y objetivo                                    |
| Esfuerzo / Capacidad | Requiere diseño propio del marco                                                         | Alta carga analítica por escenario      | Requiere coordinación entre áreas y acuerdo sobre los resultados esperados. |
| Límite Crítico       | No entrega tablas listas para usar                                                       | No aborda el tratamiento ni el gobierno | No calcula ni prioriza el riesgo real                                       |

# ¿Cómo Elegir? (Árbol de Decisión)



## Ejemplo Aplicado: Organización Pequeña

Escenario: 1 encargado de TI/Seguridad a media jornada.

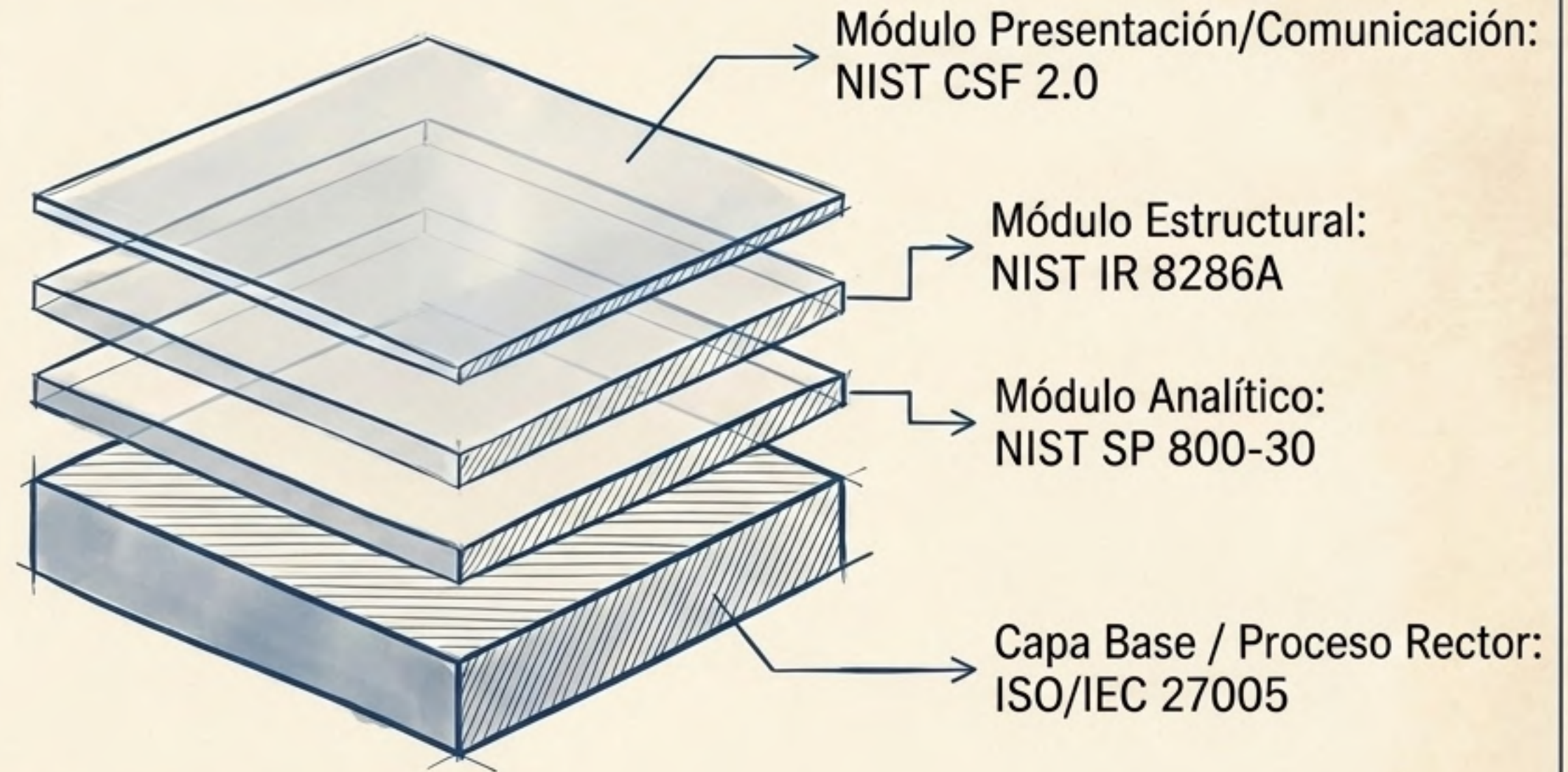
### Decisión Arquitectónica:

No tiene capacidad para aplicar SP 800-30 completo a cada activo. Necesita un proceso rector simplificado (basado en eventos de ISO 27005) para no paralizarse por exceso de análisis teórico.

Regla: Una obligación legal o contractual actúa como requisito del proceso, no como un riesgo que la organización pueda decidir ignorar o aceptar. El árbol debe seguir considerando decisión, capacidad del equipo, disponibilidad de datos y obligaciones existentes como factores para seleccionar y adaptar referencias. No No conviertas las obligaciones legales o contractuales en una opción equivalente a los demás criterios.

# Arquitectura metodológica: rector + apoyos

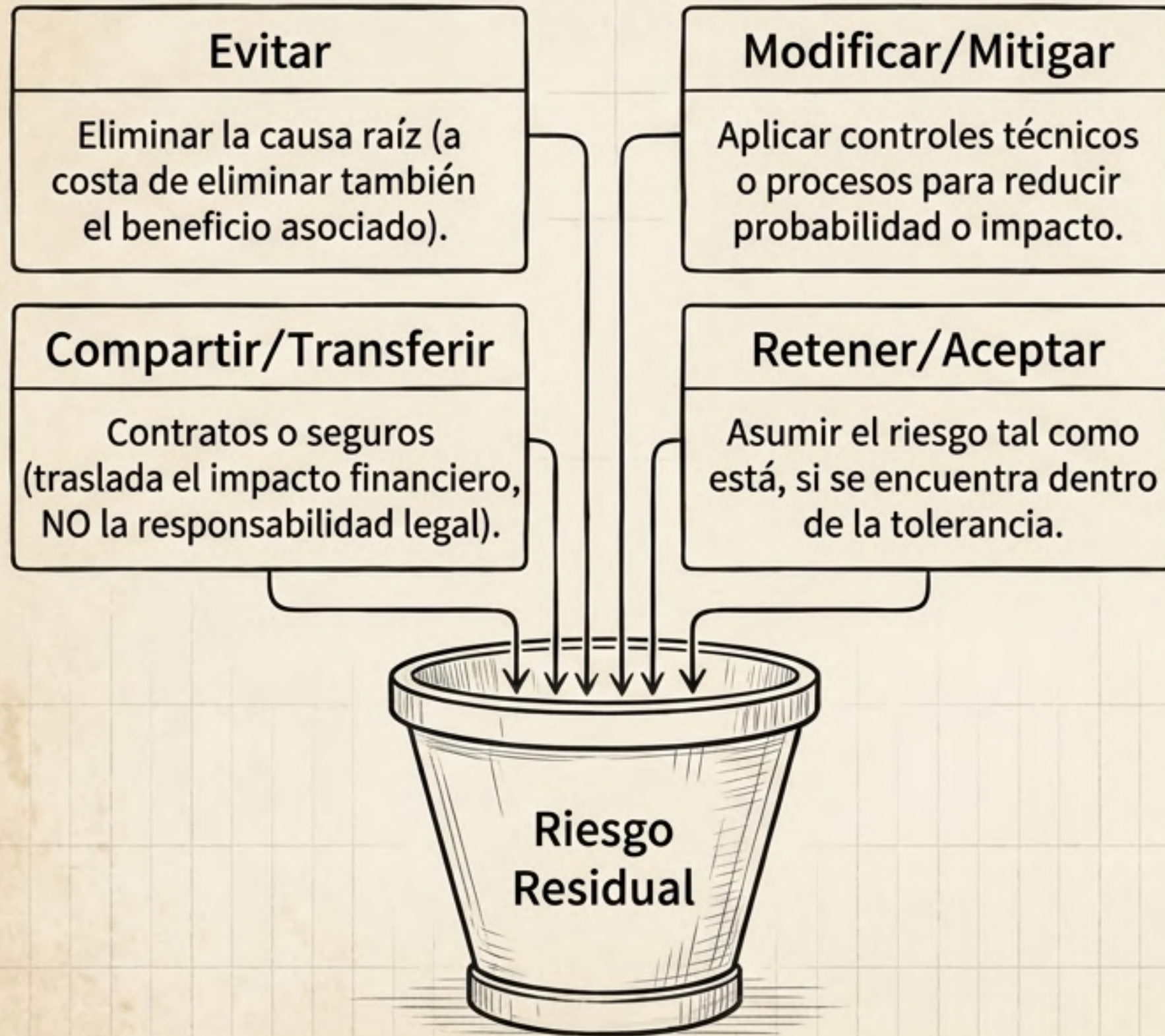
Las referencias no compiten necesariamente. Se puede construir un proceso con una referencia rectora y complementos acotados para funciones específicas.



- No es obligatorio utilizar todas las referencias.
- Todas deben trabajar con la misma escala organizacional definida previamente.

|  |  |  |  |  |  |
|--|--|--|--|--|--|
|  |  |  |  |  |  |
|  |  |  |  |  |  |
|  |  |  |  |  |  |
|  |  |  |  |  |  |
|  |  |  |  |  |  |
|  |  |  |  |  |  |

# Opciones de Tratamiento y la Realidad del Riesgo Residual



## Responsabilidad de Aceptación

La aceptación del riesgo residual corresponde a quien posee autoridad sobre el proceso afectado, no automáticamente al área de seguridad.

Nota: No se desarrollan aquí cálculos de riesgo residual ni priorización de tratamientos, que corresponden a etapas posteriores.

|          |                              |           |              |
|----------|------------------------------|-----------|--------------|
| PROJECT: | Risk Management Architecture |           |              |
| DATE:    | OCT 26, 2024                 | DRAWN BY: | AI Architect |
| SCALE:   | NTS                          | SHEET NO: | 09           |

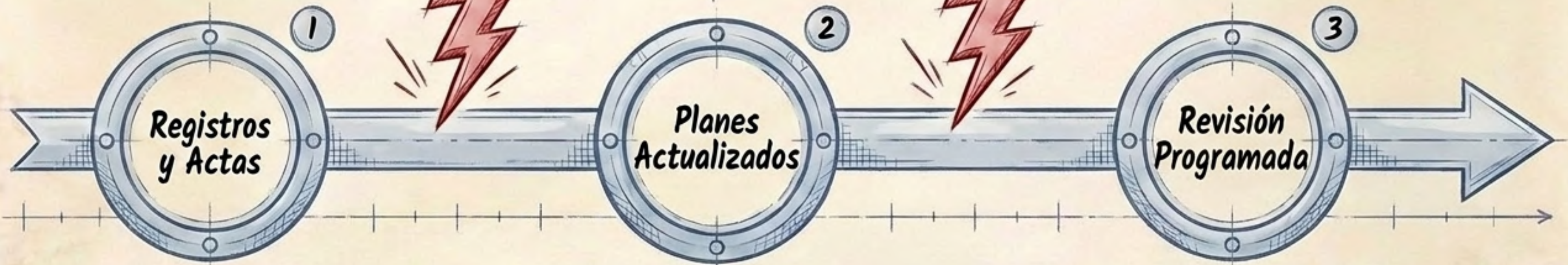
# Mantener el Ciclo Vivo

El ciclo muere si se convierte solo en un documento de Excel archivado.

## Disparadores de Revisión

No se espera al calendario anual si ocurre un evento disruptivo:

- ✓ Un incidente de ciberseguridad grave.
- ✓ Cambio de un proveedor tecnológico clave.
- ✓ Implementación de un nuevo sistema core.
- ✓ Un cambio repentino en la normativa legal.



# Síntesis de la Lección 08

## Blueprint Flow

1. Necesidad de Decisión



2. Referencia Adecuada (Rector + Apoyo)



3. Resultado (Una Sola Escala)



4. Evidencia (Registro Estructurado)



5. Revisión Continua (Disparadores)

## Autoevaluación:

1. ¿Por qué una guía de evaluación (SP 800-30) no sirve como proceso de gestión único?
2. ¿Qué comunica un perfil de CSF y qué es incapaz de calcular por sí solo?
3. ¿Por qué un puntaje CVSS de 9.0 choca con nuestra matriz si no lo traducimos?
4. ¿Quién debe firmar la aceptación del riesgo residual y por qué?

Signature



|                                      |                     |            |           |
|--------------------------------------|---------------------|------------|-----------|
| PROJECT: Risk Managment Architecture |                     |            | SREE1110: |
| DATE: OCT 26, 2024                   | RAMVRW: AI Archtaot | SCALE/ NTS | 18        |